

CYBERSECURITY ASSESSMENT LAB

Portfolio Technical Report

Authorized assessment of an intentionally vulnerable Metasploitable 2 virtual machine in an isolated VMware laboratory.

Student	Mohamed Naasif
Assessment workstation	Kali Linux - 192.168.216.131
Target	Metasploitable 2 - 192.168.216.132
Lab network	Private VMware 192.168.216.0/24
Assessment period	September 2026

Project objective: demonstrate a repeatable security-assessment workflow from discovery through vulnerability analysis, packet inspection and digital forensics.

1. Executive Summary

This project recreates a compact, portfolio-focused cybersecurity assessment against an intentionally vulnerable Metasploitable 2 virtual machine. **The work was performed only inside a controlled VMware lab.** Kali Linux was used for reconnaissance and analysis, while Nmap, OWASP ZAP, Greenbone/OpenVAS, Wireshark and Autopsy were used to investigate different security layers.

The assessment demonstrated the following workflow:

- Identify exposed services and versions with Nmap.
- Enumerate the web services and inspect HTTP response headers.
- Assess the web application with OWASP ZAP and document representative findings.
- Run Greenbone/OpenVAS and investigate representative Critical findings.
- Capture and analyze ICMP, ARP, TCP and HTTP traffic with Wireshark.
- Inspect the Metasploitable 2 VMDK, filesystem metadata and deleted entries with Autopsy.

2. Scope and Lab Topology

Component	Role	Address / Notes
Kali Linux	Assessment / analysis workstation	192.168.216.131
Metasploitable 2	Authorized vulnerable target	192.168.216.132

Safety boundary: The target was an intentionally vulnerable VM in a private VMware network. No public or third-party systems were tested, and no exploit execution was required to complete the assessment evidence.

3. Nmap Reconnaissance

Command used: **nmap -sV 192.168.216.132**

Nmap confirmed the host was reachable and identified 23 open TCP services. Key examples included:

- 21/tcp - FTP (vsftpd 2.3.4)
- 22/tcp - SSH (OpenSSH 4.7p1)
- 23/tcp - Telnet
- 80/tcp - HTTP (Apache 2.2.8, Ubuntu; PHP 5.2.4 reported later in headers)
- 1524/tcp - bindshell
- 3306/tcp - MySQL 5.0.51a
- 5432/tcp - PostgreSQL 8.3.x
- 5900/tcp - VNC
- 8180/tcp - Apache Tomcat 5.5

Evidence file: *evidence/nmap-service-scan.txt*

4. HTTP Enumeration and Header Analysis

Nmap scripts were used to identify page titles and response headers on ports 80 and 8180: **nmap -p 80,8180 --script http-title,http-headers 192.168.216.132**

The assessment reported:

- Port 80: Apache/2.2.8 (Ubuntu) DAV/2 and X-Powered-By: PHP/5.2.4-2ubuntu5.10.
- Port 8180: Apache-Coyote/1.1 with Apache Tomcat 5.5 identified by the page title.
- Both services returned HTTP 200 responses to the header checks.

Security observation: The response headers expose software and platform information. This is useful for reconnaissance and version identification and should be minimized where practical.

5. OWASP ZAP Web Security Assessment

Target: <http://192.168.216.132>

ZAP generated 25 alerts. Three representative findings were selected for deeper documentation. The project deliberately avoids treating every scanner alert as a confirmed exploitable vulnerability; risk and confidence are recorded as ZAP reported them.

Finding	Risk	Confidence	CWE	Recommended action
Absence of Anti-CSRF Tokens	Medium	Low	352	Implement validated CSRF protection on state-changing forms.
Content Security Policy (CSP) Header Not Set	Medium	High	693	Configure an appropriate Content-Security-Policy header.
Cookie No HttpOnly Flag (PHPSESSID)	Low	Medium	1004	Set HttpOnly on session cookies where client-side access is not required.

6. Greenbone / OpenVAS Vulnerability Assessment

A fresh task was created specifically for this portfolio project: **Metasploitable 2 - Full Vulnerability Assessment**

The completed Results view showed the following categorized counts:

Severity	Results
Critical	13
High	11
Medium	40
Low	6
Log	90

Total shown in the severity breakdown: 160 categorized results.

Three Critical findings were investigated in detail:

- Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities - severity 10.0, QoD 99%, 8787/tcp. Greenbone reported a potentially dangerous remote command execution condition in the exposed DRb service.
- Possible Backdoor: Ingreslock - severity 10.0, QoD 99%, 1524/tcp. Greenbone reported a detection response showing uid=0(root) gid=0(root).
- TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities - severity 10.0, QoD 80%, 80/tcp. Greenbone reported affected TWiki versions prior to 4.2.4 and recommended upgrading to 4.2.4 or later.

7. Wireshark Traffic Analysis

A capture was performed on Kali while communicating with the Metasploitable 2 VM. The capture contained several useful protocol examples:

- ARP address-resolution traffic between the two lab VMs.
- ICMP echo request/reply traffic generated with ping.
- TCP three-way handshake traffic for the HTTP connection (SYN, SYN/ACK, ACK).
- HTTP GET / HTTP/1.1 request followed by HTTP/1.1 200 OK response.

Security observation: HTTP application data was directly visible in the packet capture because the service used unencrypted HTTP on TCP port 80. Sensitive application traffic should use HTTPS/TLS to protect data in transit.

8. Autopsy Digital Forensics

A fresh Autopsy case was created to examine the Metasploitable 2 VMDK. The virtual disk was approximately 1.9 GB and contained two relevant partitions:

Partition	Type	Sector range	Observed filesystem
1	Linux (0x83)	63 - 481949	ext
2	Linux LVM (0x8e)	482013 - 16771859	raw / LVM container

The ext filesystem was opened in File Analysis mode. Autopsy exposed file and metadata information including timestamps, size, UID/GID and metadata identifiers. The Deleted Files view identified entries including GRUB backup/temporary files and older kernel-related files.

Forensic interpretation note: Deleted or orphaned entries were treated as artifacts requiring context, not as automatic evidence of malicious activity.

9. Key Findings and Recommendations

Area	Key finding	Recommended action
Reconnaissance	23 TCP services exposed on the target.	Minimize unnecessary services and restrict management interfaces.
Web headers	Apache/PHP/Tomcat technology details exposed.	Reduce unnecessary version/banner disclosure and keep software supported.
ZAP	CSRF, CSP and HttpOnly-related alerts identified.	Implement CSRF protection, CSP and secure cookie attributes as appropriate.
OpenVAS	Critical findings included DRb RCE, possible Ingreslock backdoor and vulnerable TWiki.	Disable/uninstall unnecessary services, isolate vulnerable components and patch/replace unsupported software.
Wireshark	HTTP traffic visible in clear text.	Use HTTPS/TLS for sensitive web traffic.
Autopsy	Deleted and boot-related filesystem artifacts identified.	Preserve evidence, investigate artifacts in context and maintain chain-of-custody practices in real investigations.

10. Limitations and Responsible Use

- The environment is intentionally vulnerable and should not be exposed to untrusted networks.
- Scanner findings are reported with their stated risk and confidence; a scanner alert is not automatically proof of successful exploitation.
- No destructive exploitation was required for this portfolio project.
- The private 192.168.216.x addresses are lab-only evidence.

11. Conclusion

The assessment demonstrates a complete beginner-to-intermediate security workflow: discover the attack surface, enumerate web technologies, assess vulnerabilities, inspect network traffic, and perform basic digital forensics. The project produced reproducible evidence, representative findings, and remediation-oriented documentation suitable for a cybersecurity portfolio.